Validate safely. Deliver with evidence.

A Python/FastAPI transaction-validation API with reproducible CI, security gates and observable local operation.

Business boundary
Evaluate synthetic transactions.
No money transfer, balance store or real customer data.

Honest scope
Local implementation verified.
Managed Kubernetes and cloud delivery remain deferred—not demonstrated.

Tasks 1–7 covered: application, containers, deployment intent, CI/CD, security, observability and documentation/AI proposal.

GitHub repository and project files

Strict input boundaries; pure transaction rules

- **GET /health**: liveness, not business correctness.
- **POST /validate**: five required string fields; unknown fields rejected.
- Decimal money; no float intermediates, coercion or silent rounding.
- Positive amount, limit, currency, precision and distinct-account rules.

```
Accepted → HTTP 200
{"valid":true,"errors":[]}

Business rejection → HTTP 200
{"valid":false,
 "errors":["AMOUNT_NOT_POSITIVE"]}

Malformed/schema input → HTTP 422
Sanitized error metadata
```

Examples illustrate the contract; they are not a new execution trace.

Choices: FastAPI/Pydantic instead of Spring Boot; uv/pytest instead of Maven/JUnit. API, schemas, pure services and instrumentation stay separate. Step branches are reviewed before main publication.

Portable artifacts ≠ a proven cloud deployment

Implemented and verified

- Locked runtime and pinned image inputs.
- Historical public ARM64/AMD64 release **0.2.0**; platform checks documented.
- Gated local ARM64 CI archives with source/image/checksum provenance.
- Non-root application; read-only root, dropped capabilities and resource limits.

Public Docker Hub repository

Deployment intent only

- Kubernetes manifests and runtime safeguards exist.
- No managed cluster or two Ready pods verified.
- No live rollout, pod recreation or rollback demonstrated.
- New CI registry promotion, provider access, costs and teardown await approval.

The older manifest image is not the newer logging demonstration image.

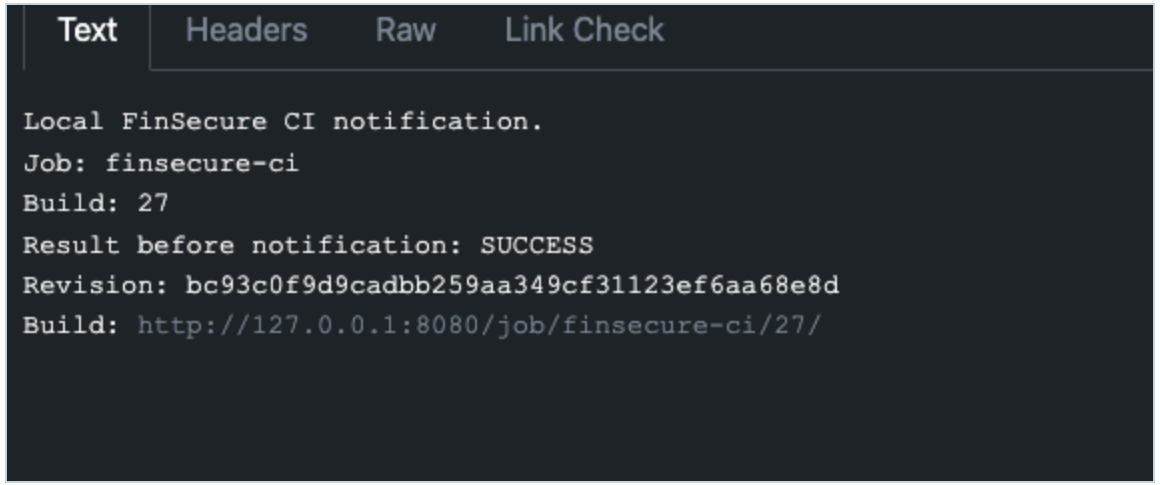
Automatic builds with verifiable outputs

655 tests • 33 artifacts

Representative published SCM build **#27**: SUCCESS, exact revision **bc93c0f**, all existing gates passed.

Current baseline #30 also passed; its local observation is separate from the published #27 record linked below.

```
Trusted main → locked install
→ lint / format / tests
→ source + dependency gates
→ package / BuildKit image
→ image gate → archive
→ result notification
```



Actual message-panel crop from the retained screenshot. No text was replaced or added to the image.

Local SMTP only, not internet mail. The evidence link contains the original screenshot, raw receipt and verified artifact hashes.

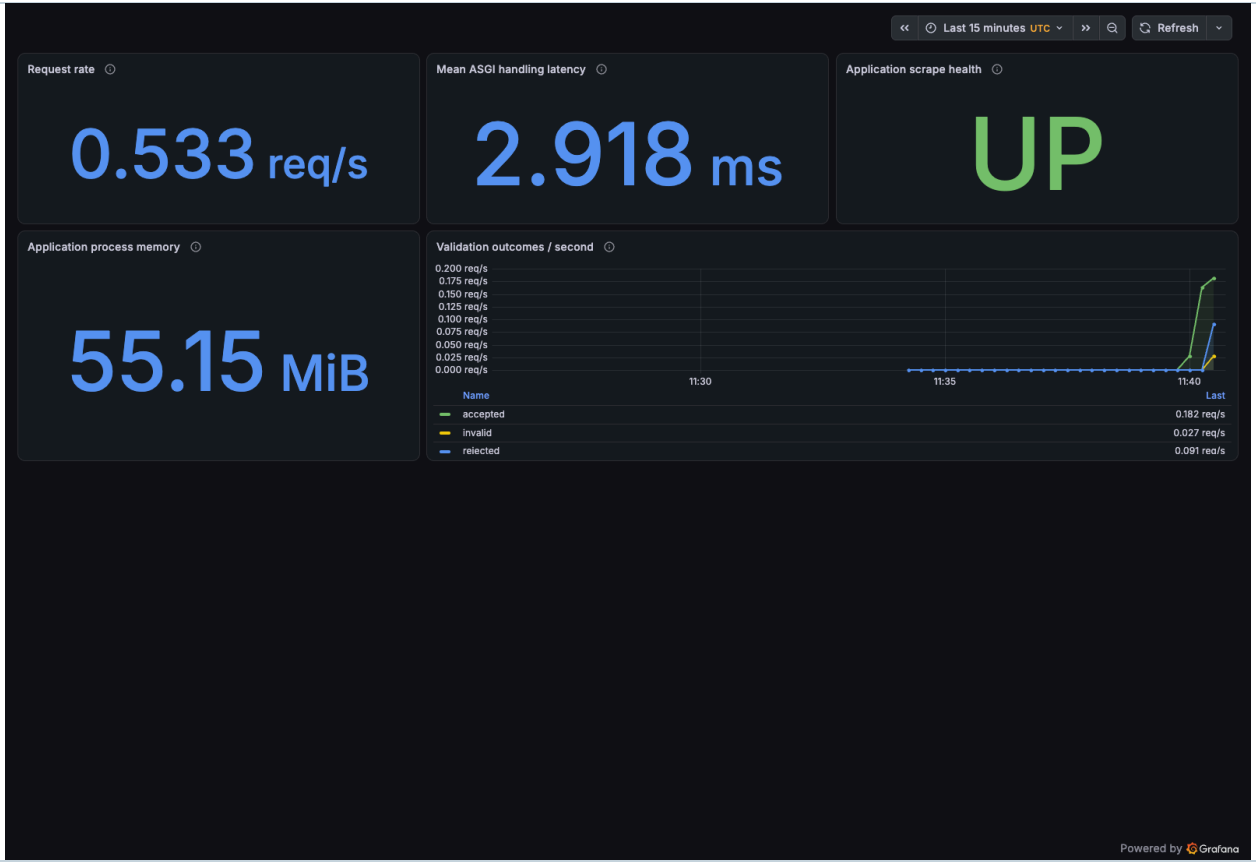
Failures block artifacts—not just dashboard colours

Actual demonstration	Observed result	Boundary
Controlled pytest failure Isolated gate-demo #3	245 passed / 1 failed Package and image export skipped	Real test failure; no deployment stage existed
Controlled vulnerable image Isolated security job #1	61 HIGH / 2 CRITICAL Image archive withheld	Artifact not run or deployed
Restored Alpine baseline	503 tests; image gate passed 33 artifacts verified	Historical remediation run, not latest test count

Layered checks
Bandit, pip-audit and Trivy; lock-bound hashes, freshness and identity checks. Invalid scans fail closed.

Limits remain visible
29 LOW Bandit findings in later CI. Clean image report means no known findings in that snapshot. Third-party-SBOM caveat retained.

Metrics, real alerts and privacy-safe logs



Actual Step 6.2 screenshot: bounded 60-request demonstration. Not a load benchmark or cloud dashboard.

Prometheus + Grafana: bounded labels; request rate, latency, health, RSS and outcomes.

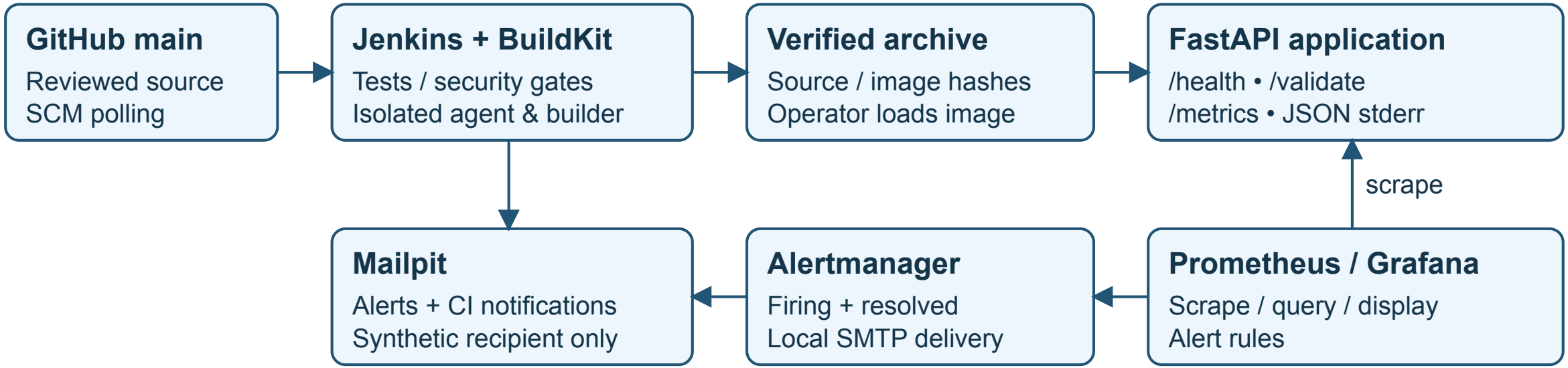
Alertmanager → Mailpit: real firing and resolved messages after an owned local outage. Stop interval: **122.22 s**.

JSON logs: accepted/rejected/invalid outcomes; no bodies, identifiers, headers or query values.

```
Actual log fields (excerpt):
"event":"validation_outcome",
"outcome":"rejected",
"codes":["AMOUNT_NOT_POSITIVE"]
```

Excerpt from candidate 1a1f4a3; full timestamped record linked. Centralized cloud logging deferred.

Source-to-runtime flow and trust boundaries



Deferred: CI registry promotion → managed Kubernetes → centralized cloud logs

Historical public 0.2.0 exists; manifests are not evidence of a running cluster. No AI service deployed.

Controller has zero executors. Agent and rootless builder are separate containers; no host Docker socket for the agent. SMTP is local. Model/service integration is not part of the running architecture.

Advisory incident triage, not autonomous remediation

Problem & proposed integration

Operators navigate separate alerts, metrics, logs and runbooks. AI could assemble a cited timeline and highlight missing evidence.

> Sanitized alert + approved evidence
> → bounded model input
> → schema/citation validation
> → human-reviewed summary

Inputs: safe logs, bounded metric samples, verified deployment history and reviewed runbook sections. No secrets or direct tool access.

Benefit, risks & evaluation

- Expected benefit: less navigation time and clearer handoffs; **not measured**.
- Guard against hallucinations, prompt injection, disclosure, stale evidence and cost escalation.
- Separate facts from hypotheses. Missing diagnostics mean cause remains unknown.
- Compare against human/runbook and deterministic-template baselines.
- Human approval for actions; no mutation capability.

> **No deployed AI model required or implemented.** Provider, budget, retention and access remain undecided. Example output is authored illustration.

Full use-case proposal and synthetic example

What is proven—and what is still missing

Assignment test	Current evidence / gap
Unit tests pass	Verified: 655 tests in normal SCM CI
Controlled failing test blocks deployment	Partial: pytest failure blocks package/image export; cloud delivery absent
Container /health responds	Verified on historical releases and exact gated local images
At least two application pods Ready	**Missing: no managed-cluster execution**
New image rollout succeeds	**Missing: no live Kubernetes rollout**
Deleted/restarted pod recreated	**Missing: local container restart is not pod self-healing**
HIGH/CRITICAL finding blocks release	Partial: verified image-archival block; registry/deployment path absent
Monitoring condition sends notification	Verified locally: actual firing and resolved SMTP receipts

Deferred requirements are not waived. This presentation does not claim complete cloud acceptance.

Keep provenance stronger than the success badge

Lessons from actual failures

- Build #22: scanner panic, then Docker I/O errors. Approved recovery restored access—not proof of full volume integrity.
- A loaded configuration can keep working while its file bind is unreadable. Check bytes and mounts, not email alone.
- Persist actual checkout revision; an inline probe is not automatic SCM proof.
- Retain failed reports and distinguish image archive, loaded image and deployment.

Remaining work

- Agree provider/account eligibility, spending, exposure and teardown before cloud work.
- Demonstrate two Ready pods, rollout, pod recreation and cloud delivery/log collection.
- Rehearse and time the 10–15-minute demonstration in Step 7.4; not yet completed.
- Review this PDF before submission. Do not upload secrets or unreviewed logs.

Repository • Registry • Evidence index

> Public repository links are evaluator entry points. Local Jenkins/Grafana/Mailpit URLs are not remotely accessible. No cloud credentials, new model or public service are created for this deck.